

SQL Injection Allowing Authentication Bypass

1. Vulnerability Overview

- **Vulnerability Type:** SQL Injection — Authentication Bypass
- **Security Impact:** Unauthorized Authentication
- **Primary Objective:** Gain unauthorized access to the application as the **administrator** user.

2. Vulnerability Description

The application's login functionality improperly handles user-controlled input supplied through the authentication parameters.

Because the input is incorporated into the underlying SQL authentication query without adequate parameterization, an attacker may manipulate the query logic and interfere with the password verification condition.

This can result in authentication being granted without valid credentials.

3. Attack Vector & Exploitation Methodology

The assessment begins by identifying the username parameter used by the application's authentication query.

An attacker can provide specially crafted SQL syntax designed to alter the original query structure and neutralize subsequent authentication conditions.

If the application fails to properly parameterize the input, the modified query may evaluate as valid and authenticate the attacker as the targeted account.

4. Security Impact

Successful exploitation may allow an unauthorized attacker to:

- Bypass normal authentication controls.
- Access another user's account.
- Impersonate a privileged user such as **administrator**.
- Access functionality and data protected by the compromised account.

5. Root Cause

The vulnerability is caused by unsafe construction of authentication queries using untrusted user input.

The application's authentication layer does not adequately separate user-supplied data from executable SQL syntax.

6. Remediation

- Use **parameterized queries / prepared statements** for all authentication-related database operations.
- Never construct SQL authentication queries through direct string concatenation.

- Apply server-side input validation as an additional defensive layer.
- Implement appropriate account authorization controls independently from authentication.
- Follow the **Principle of Least Privilege** for application and database accounts.

7. Security Recommendation

Authentication mechanisms should rely on secure parameterized database access and should never allow user-controlled input to modify the logical structure of an authentication query.

Author: Moe Htet Ar Kar (Phoe Cho)